AI 보안 및 리스크 관리 보고서

의료 AI 보안 위협 분석

학번/성명:	202221027/임창섭	시나리오:	A
팀원 이름:	양준형, 조현호, 김윤재, 임창섭		

활동 안내

암 진단 AI 시스템을 도입하려는 병원을 대상으로 AI 보안 위협을 식별하고 대응 방안을 설계합니다.

- 과제 1: AI 보안 위협 식별 및 영향 분석
- 과제 2: 이해관계자 보안 요구사항 분석
- 과제 3: 기술적·관리적 대응 방안 설계
- 과제 4: 종합 보안 권고 보고서

시나리오 A: 의료 AI 보안 위협 분석

서울 소재 대형 종합병원 '한국의료원'은 방사선 영상(X-ray, CT, MRI)을 분석하여 암을 조기 진단하는 AI 시스템을 도입하려 합니다. 이 AI는 수십만 건의 환자 영상 데이터로 학습되었으며, 의사의 진단을 보조하는 역할을 수행합니다. 이 병원은 AI 도입 전에 체계적인 보안 위협 분석을 실시하고자 합니다.

- AI 시스템에 고유하게 발생하는 보안 위협의 종류를 이해한다
- 실제 사례에 AI 보안 위협 개념을 적용할 수 있다
- 각 위협에 대한 기술적·관리적 대응 방안을 설계한다
- AI 보안 생태계의 이해관계자 구조를 파악한다

서론

최근 의료 분야에서는 인공지능 기술을 활용하여 의료 영상 분석, 질병 예측, 환자 진단 지원 시스템 등의 다양한 서비스를 제공하며 정확성과 효율성이 크게 향상되고 있다. 그 중에서 특히 방사선 영상(X-ray, CT, MRI)을 분석하는 의료 AI 시스템은 암과 같은 질병을 조기에 발견하는데 도움을 주고 있다. AI 시스템은 데이터와 알고리즘 등 여러 요소로 구성되는데 때문에 여러 방식으로 AI 시스템 자체를 공격 대상으로 하는 보안 위협도 증가하고 있는 추세이다. 이는 특히 환자의 생명과 의료 서비스의 신뢰성에 직접적인 영향을 미칠 수 있어 보안 위협이 더욱 심각한 문제로 간주된다. 특히 데이터 포이즈닝 공격, 적대적 공격, 민감 데이터 노출, 모델 절취 공격을 중심으로 의료 AI 보안 문제를 분석하고 대응 방안을 제시하며 추가적으로 의료 AI 시스템에서는 데이터 편향 문제도 중요한 위험 요소로 지적되고 있지만, 본 보고서는 AI 보안 위협 분석을 목적으로 하기 때문에 외부 공격자가 악용할 수 있는 보안 위협을 중심으로 분석하였다.

AI 보안 위협 식별 및 영향 분석

AI 보안은 단순한 사이버 보안 문제를 넘어 데이터 보호, 모델 무결성, 시스템 신뢰성을 모두 포함하는 개념이다. AI 시스템이 공격에 노출될 경우 데이터 유출, 잘못된 의료 판단, 시스템 오작동이 발생할 수 있다. 따라서 서울 소재 대형 종합병원인 한국의료원이 도입하려는 의료 영상 분석 AI 시스템을 대상으로 보안 위협을 식별하고 실제 사례를 통해 그 위험성을 살펴보겠다. 의료 AI 시스템은 일반적인 소프트웨어와 달리 대규모 의료 데이터와 머신러닝 모델을 기반으로 작동하는데 이러한 구조 때문에 기존의 사이버 공격뿐 아니라 AI 모델 자체를 대상으로 하는 새로운 형태의 공격이 등장하고 있다. 대표적인 AI 공격 유형으로 데이터 포이즈닝 공격, 적대적 공격, 민감 데이터 노출, 모델 절취 공격 4가지를 의료 AI 시스템 보안과 가장 관련성이 높은 위협으로 선정하여 아래의 표를 통해 각 위협에 대한 설명과 AI 적용 시나리오, 환자, 병원, 사회 등 예상되는 피해를 분석해보겠다.

위협	위협 설명	의료 AI 적용 시나리오	예상 피해
데이터 포이즈닝	학습 데이터에 조작된 데이터를 삽입하여 AI 모델의 성능을 조작하는 공격	폐암 진단을 위해 의료 영상 데이터를 학습하는 AI 모델이 있다고 가정한다. 만약 공격자가 학습 데이터에 정상 폐 X-ray 이미지를 암 환자의 데이터로 잘못 표시하거나 조작된 이미지를 삽입한다면, AI 모델은 잘못된 패턴을 학습하게 된다. 그 결과 실제 환자의 폐 X-ray 영상을 분석할 때 암이 존재함에도 이를 정상으로 판단하거나 반대로 정상 이미지를 질병으로 판단하는 오류가 발생할 수 있다.	잘못된 진단, 환자 치료 지연, 환자 안전 위험
적대적 공격	AI 모델의 입력 데이터에 아주 미세한 변형을 추가하여 잘못된 결과를 출력하게 하는 공격	병원에서 사용하는 X-ray 기반 폐 질환 진단 AI 시스템이 있다고 가정한다. 공격자가 의료 영상에 사람의 눈으로는 거의 인식하기 어려운 미세한 노이즈나 변형을 추가하면 AI 모델의 판단 결과가 크게 달라질 수 있다. 예를 들어 실제로 폐암이 존재하는 X-ray 이미지에 미세한 변형을 추가했을 때 AI가 이를 정상 폐 이미지로 판단하거나, 반대로 정상 이미지를 폐암으로 오진하는 상황이 발생할 수 있다.	암 환자 미진단, 의료사고 발생, 환자생명 위협, 병원 신뢰도 하락

민감 데이터 노출	학습데이터 또는 AI 모델에서 환자의 개인 정보나 의료데이터가 외부로 유출되는 위험	병원에서 환자의 진료 기록, 의료 영상, 유전자 정보 등을 활용하여 AI 진단 모델을 개발한다고 가정한다. 만약 시스템 보안이 충분하지 않거나 AI 모델을 통해 학습 데이터가 추론될 수 있다면 공격자가 모델 분석을 통해 환자의 개인정보나 의료 기록을 유추할 수 있다. 이러한 경우 환자의 질병 정보나 개인 의료 데이터가 외부로 유출되는 문제가 발생할 수 있다.	개인 정보 침해, 의료 정보 유출, 법적 책임 발생, 병원 평판 손상
모델 절취 /역공학	공격자가 AI서비스 API를 반복적으로 호출하여 AI 모델의 구조와 기능을 복제하거나 지적 재산을 탈취하는 공격	병원이 웹 기반 의료 AI 진단 서비스를 제공하고 있다고 가정한다. 사용자는 의료 영상을 업로드하면 AI가 분석 결과를 제공하는 방식이다. 공격자가 이 서비스를 반복적으로 호출하여 다양한 입력 데이터를 전송하고 결과를 분석하면 AI 모델의 동작 방식과 구조를 추정할 수 있다. 이러한 과정을 통해 공격자는 유사한 AI 모델을 복제하거나 병원이 개발한 AI 기술을 무단으로 탈취할 수 있다.	병원의 AI 기술 유출, 경쟁력 약화, 보안 취약점 악용, 연구 비용 손실

데이터 포이즈닝 공격 연구, 적대적 공격 연구, 모델 절취/역공학 위협은 실제 사례보다는 많은 연구자료를 볼 수 있었다. 데이터 포이즈닝 공격에 관한 폐렴 진단 AI 모델 데이터 포이즈닝 실험, 적대적 공격에 관한 의료 영상 AI에 대한 공격 연구가 모델 절취/역공학 위협에서는 머신러닝 API 모델 절취 공격 연구가 진행되었다.

민감 데이터 노출 실제 사례

2018년 싱가포르의 의료 기관 SingHealth에서 대규모 사이버 공격이 발생하여 약 150만명의 환자 정보가 유출되었다. 유출된 정보는 이름, 주소, 생년월일 등의 민감한 개인정보가 포함되어 있는 것으로 알려졌다. 최근에도 의료 데이터 유출 사고는 계속 발생하고 있으며, 미국 의료 시스템에서 560만 명 이상의 정보도 유출된 사건을 찾아볼 수 있었다.

이러한 공격들은 AI 모델의 학습 과정이나 추론 과정에서 발생할 수 있으며, 공격자는 이를 통해 AI의 판단을 조작하거나 데이터를 탈취할 수 있다. 따라서 의료 AI 시스템에서는 일반적인 정보보안뿐 만 아니라 AI 모델 자체에 대한 보안 관리가 필수적이다.

데이터 포이즈닝 공격 연구 사례
https://pubmed.ncbi.nlm.nih.gov/40593872/
적대적 공격연구 사례
https://koreascience.or.kr/article/CFKO202532539696403.page
모델 절취/역공학 공격 연구 사례
https://arxiv.org/abs/1805.02628 , https://arxiv.org/abs/1909.01838
민감데이터 노출 사례
https://en.wikipedia.org/wiki/2018_SingHealth_data_breach
https://www.ctinsider.com/business/article/yale-new-haven-health-data-breach-20292710.php?utm_source=chatgpt.com

이해관계자 보안 요구사항 분석

구분	이해관계자	역할	보안 관심사	구체적 요구사항
내부	병원 경영진	병원 운영 및 AI 도입 결정, 전체적인 관리 책임	의료 데이터 보호, 법적 책임, 병원 평판 관리	의료 데이터 보호 정책 수립, 보안 투자 확대, 관련 법규 준수 체계 구축
내부	의료진	AI 기반 진단 시스템을 활용하여 진단 및 치료 과정에 활용	AI 진단 정확성, 시스템 신뢰성, 환자 안전	AI 결과의 신뢰성, 시스템 안정성, AI 판단 결과 검증
내부	IT 보안팀	병원의 정보 시스템과 AI 시스템의 보안 관리 및 유지	데이터 보호, 시스템 보안, 접근 권한 관리	네트워크 보안 강화, 데이터 암호화, 접근 통제 및 보안 모니터링 체계 구축
외부	환자	의료 서비스를 이용하며 자신의 의료 데이터를 병원에 제공	개인정보 보호, 정확한 의료 서비스 제공	개인 의료 데이터 보호, 데이터 익명화, 정확한 AI 진단 제공
외부	AI 개발사	의료 AI 시스템 개발 및 유지관리	AI 모델 보호, 데이터 품질	모델 보안 강화, API 접근 제어, 기술 보호 정책 마련
외부	정부 및 규제 기관	의료 데이터 보호 및 AI 규제 감독	개인정보 보호, 의료 AI 안정성 확보, 법적 규제 준수	의료 데이터 보호 법규 준수, AI 윤리 및 안정성 검증, 보안 감사 및 관리

의료 AI 시스템은 병원 내부 구성원뿐만 아니라 환자, AI 개발사, 정부 기관 등 다양한 이해관계자가 참여하는 구조를 가지고 있다. 따라서 의료 AI 보안을 효과적으로 관리하기 위해서는 각 이해관계자의 역할과 보안 요구사항을 명확히 이해하고 이에 맞는 보안 정책을 수립하는 것이 중요하다.

기술적 관리적 대응 방안 설계

위협	기술적 대응	관리적 대응	기대 효과
데이터 포이즈닝	학습 데이터 무결성 검증 시스템 구축, 데이터 이상 탐지 알고리즘 적용, 데이터 수집 과정에서 검증 및 필터링 기술 적용	데이터 관리 정책 수립, 신뢰할 수 있는 데이터 출처 사용, 데이터 관리 및 검증 절차 마련	조작된 데이터가 학습 과정에 포함되는 것을 방지하여 AI 모델의 신뢰성과 정확성을 유지할 수 있음
적대적 공격	Adversarial Training 적용, 입력 시스템 구축, 모델 강건성 강화 기법 적용	AI 모델 보안 테스트 수행, 의료 AI 사용 전 검증 절차 마련, 보안 점검 및 정기 평가 실시	입력 데이터 조작에 대한 모델의 대응 능력을 강화하여 AI 진단 오류 발생 가능성을 감소

민감 데이터 노출	의료 데이터 암호화, 접근 관리 시스템 적용, 데이터 익명화 및 보안 로그 모니터링 시스템 구축	개인정보 보호 정책 수립, 의료 데이터 접근 권한 관리 규정 마련, 보안 교육 및 관리 감독 강화	환자 개인정보와 의료 데이터 보호 강화 및 데이터 유출 사고 예방
모델 절취/ 역공학	API 접근 제어 및 인증 강화, 요청 횟수 제한, 모델 난독화 및 보호 기술 적용	AI 서비스 이용 정책 마련, 외부 접근 관리 및 보안 감사 실시, 기술 보호 정책 수립	AI 모델의 무단 복제 및 기술 유출을 방지하여 의료 AI 시스템의 지적 재산 보호

특히 의료 AI 시스템에서는 환자 생명과 직접적으로 관련된 진단 오류가 발생할 수 있기 때문에 데이터 보호와 AI 모델 보안을 동시에 고려한 종합적인 보안 관리 체계가 필요하다.

결론 - 종합 보안 권고 보고서

의료 AI 시스템은 환자의 민감한 의료 데이터를 활용하고 진단 과정에 직접적으로 영향을 미치기 때문에 보안 문제가 발생할 경우 황자의 안전과 병원의 신뢰도에 큰 영향을 줄 수 있다. 이에 따라 병원이 AI 시스템을 도입하기 전에 고려해야 할 주요 보안 위험을 설명하고, 안전한 AI 도입을 위해 필요한 보안 점검 사항과 권고 사항을 제시한다.

위협	핵심 위협 요약	우선 순위	즉시 조치 사항
데이터 조작 (데이터 포이즈닝)	의료 영상이나 입력 데이터에 미세한 변형을 추가하여 AI 모델이 잘못된 진단 결과를 출력하도록 만드는 공격	매우 높음	의료 AI 모델에 대한 적대적 공격 방어 기술 적용, 입력 데이터 이상 탐지 시스템 구축, 의료AI 모델 보안 테스트 수행
AI 입력 데이터 조작 (적대적 공격)	AI 모델 학습 데이터에 조작된 데이터를 삽입하여 모델이 잘못된 패턴을 학습하도록 만드는 공격	높음	학습 데이터 검증 절차 도입, 데이터 무결성 검증 시스템 구축, 신뢰할 수 있는 데이터 수집 및 관리 체계 마련
환자 의료 정보 유출 (민감 데이터 노출)	환자의 의료 정보와 개인정보가 시스템 취약점이나 해킹을 통해 외부로 유출되는 위협	매우 높음	의료 데이터 암호화 적용, 접근 권한 관리 강화, 개인정보 익명화 및 보안 모니터링 체계 구축
AI 기술 유출 (모델 절취 /역공학)	공격자가 AI 서비스 API를 반복적으로 호출하여 모델 구조와 기능을 분석하고 복제하는 공격	중간	API 접근 제한 및 인증 강화, 요청 횟수 제한 적용, 모델 보호 기술 및 로그 모니터링 강화

위 표에서 볼 수 있듯이 의료 AI 시스템에서 찾아볼 수 있는 위협으로는 데이터 조작, AI 입력 데이터 조작, 환자 의료 정보 유출, AI 기술 유출이 있다. 첫 번째 위협으로 데이터 조작 공격은 AI 모델의 학습 데이터에 조작된 정보가 포함될 경우 AI 시스템이 잘못된 판단을 할 수 있다. 의료분야에서는 이러한 문제가 잘못된 진단으로 이어질 가능성이 있어 위협이 된다. 두 번째로는 AI 입력 데이터 조작 공격이다. AI 시스템은 입력되는 데이터를 분석하여 결과를 제공하는데 공격자가 입력 데이터를 미세하게 변형하면 AI가 실제와 다른 판단을 하게 만들 수 있어 위협이 된다. 세 번째 위협은 환자의 의료 정보 유출인데 환자의 민감한 데이터를 활용하기 때문에 시스템 보안이 취약할 경우 외부

유출로 이어질 수 있다. 네 번째 위협으로는 AI 기술 유출 문제이다. 병원이 도입하거나 자체 개발한 AI 시스템이 외부 공격을 받을 경우 AI 모델이 복제되거나 기술이 유출될 수 있다. 이는 병원의 기술 경쟁력에도 영향을 준다.

의료 AI 시스템의 보안은 특정 부서만의 문제가 아니라 병원 내외의 다양한 이해 관계자가 함께 관리해야 하는 영역이다. 병원 내부에서는 경영진, 의료진, 그리고 IT 및 보안 담당 부서가 주요 이해관계자가 된다. 경영진은 보안 정책과 투자 방향을 결정하며, 의료진은 AI 시스템을 실제 진단 과정에서 활용하고, IT 및 보안 부서는 시스템의 안전한 운영을 담당한다. 병원 외부에서는 환자, AI 개발사, 정부 및 규제 기관이 주요 이해관계자가 된다. 환자는 자신의 의료 정보를 제공하는 당사자이며, AI 개발 기업은 시스템 기술을 제공하고 유지 관리하며 정부와 규제 기관은 의료 데이터 보호와 AI 사용에 대한 정책을 관리하게 된다. 따라서 의료 AI 시스템의 안전한 운영을 위해서는 조직 내부 보안 관리와 외부 협력 체계를 함께 구축하는 것이 중요하다.

병원이 의료 AI 도입을 위한 보안 권고 사항으로 개발 전후로 위협에 대한 대비를 해두어야 한다. AI 학습 데이터와 의료 데이터에 대한 접근 권한을 제한하고 중요한 의료 데이터는 암호화하여 관리해야 하며 개인정보 보호 정책을 강화하는 것이 필요하다. 다음으로는 AI 시스템에 대한 보안 점검을 정기적으로 수행해야 하며 명확한 보안 정책을 마련하고 AI 시스템 운영 인력에 대한 보안 교육을 실시해야 한다. AI 기술은 의료 서비스의 발전에 중요한 역할을 할 수 있지만, 동시에 새로운 보안 위험을 동반할 수 있다. 특히 의료 AI 시스템은 환자의 민감한 의료 데이터를 다루고 진단 과정에 직접적으로 영향을 미치기 때문에 보안 관리가 매우 중요하다. 따라서 병원이 AI 시스템을 도입하기 전에는 데이터 보호, AI 모델 보안, 시스템 운영 정책 등을 포함한 종합적인 보안 점검이 반드시 필요하다. 이러한 보안 관리 체계를 구축한다면 의료 AI 기술을 보다 안전하고 신뢰성 있게 활용할 수 있을 것이다.